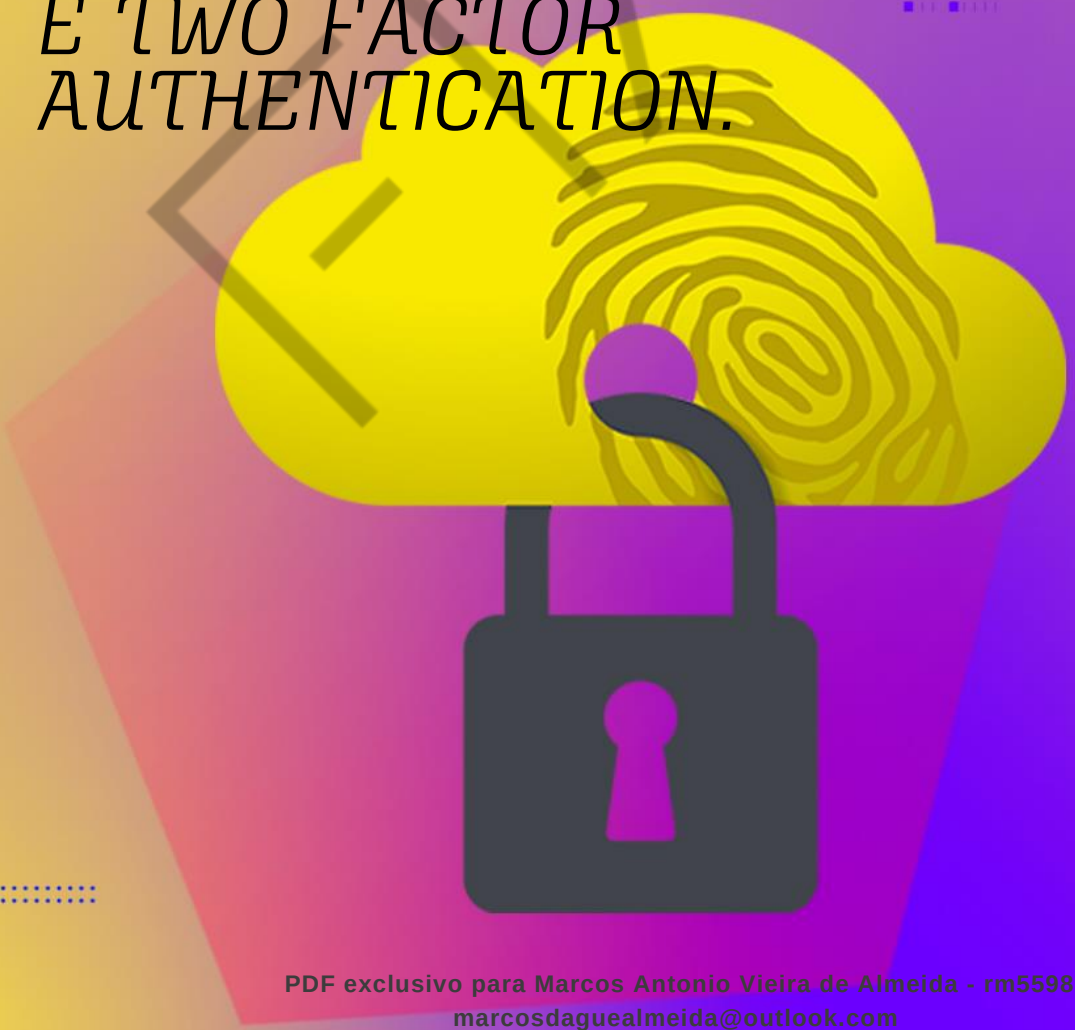
MAKING STRATEGIC DECISIONS IN THE CLOUD

CONSIDERAÇÕES DE SEGURANÇA EM AMBIENTES CLOUD. LEAST PRIVILEGE MODEL E TWO FACTOR AUTHENTICATION.



PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

LISTA DE FIGURAS

Figura 1 – Autenticação e autorização 5
Figura 2 - Benefícios do POLP 8
Figura 3 – Identidades e segurança 10
Figura 4 – Criar novo usuário 11
Figura 5 – Configurar novo usuário 11
Figura 6 – Configurar nova senha para o usuário 12
Figura 7 – Criar nova senha 12
Figura 8 – Nova senha criada 13
Figura 9 – Criar novo grupo de usuários 13
Figura 10 – Configurar novo grupo de usuários 14
Figura 11 – Adicionar membros (usuários) ao grupo 14
Figura 12 – Adicionar membros (usuários) ao grupo 15
Figura 13 – Criar política de regras 15
Figura 14 – Configurar política de regras 16
Figura 15 – Login com o novo usuário criado.....17
Figura 16 – Alterar a senha do novo usuário.....18

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

SUMÁRIO

1 ESTRATÉGIAS E TECNOLOGIAS APLICADAS À SEGURANÇA DOS AMBIENTES EM NUVEM 4
1.1 Introdução 4
1.2 Autenticação e autorização 4
1.3 Autenticação por dois fatores (Two Factor Authentication – TFA ou 2FA).....6
1.4 Princípio do privilégio mínimo.....6
1.5 Firewall e Web Application Firewall (WAF).....8
2 HANDS-ON – CRIANDO E CONFIGURANDO UMA CONTA NA NUVEM ORACLE 10
CONCLUSÃO.....19
ATIVIDADE TREINO.....20
REFERÊNCIAS.....21

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

1 ESTRATÉGIAS E TECNOLOGIAS APLICADAS À SEGURANÇA DOS AMBIENTES EM NUVEM

1.1 Introdução

A segurança em ambientes Cloud deve, no mínimo, considerar as mesmas questões que em um ambiente *on-premise*. No mínimo, pois no *on-premise* as redes são mais protegidas sendo menos expostas ao mundo externo na internet. No ambiente em nuvem, principalmente as nuvens públicas, a exposição à internet é inerente à própria operação dos serviços.

Dessa forma, as considerações de segurança devem levar em conta essa questão e fornecer recursos de proteção necessários à segurança de todos os usuários, empresas e aplicações.

A maior parte das redes de dados dos ambientes em nuvem é virtualizada e possui os mesmos recursos que o ambientes *on-premise*, entre eles o firewall, os filtros de pacote, as ferramentas antivírus e os métodos de autenticação e autorização.

Mas nada disso é suficiente se o componente de segurança principal não estiver bem alinhado e bem treinado, ou seja, os usuários obedecerem às regras de segurança propostas pelas empresas e pelos próprios provedores de nuvem.

Em vista disso, algumas estratégias podem ser estabelecidas e alguns procedimentos adotados. A seguir, são apresentados alguns desses itens.

1.2 Autenticação e autorização

Autenticação é a validação de uma credencial em um sistema, isso significa que a entrada no sistema é permitida mediante verificação positiva de uma forma de identificação.

Por exemplo, quando um aluno entra na faculdade, ele passa o crachá em alguma catraca para poder ser liberado (ou não) para entrar no ambiente físico. Nesse exemplo, o crachá é a identidade ou credencial e a catraca é a forma de validação dessa identidade.

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

No caso de sistemas digitais, a principal forma de autenticação é por meio de um usuário (login) e a respectiva senha. Outros meios também têm sido bastante utilizados, como os acessos por biometria (digital, íris dos olhos, rosto, voz etc.).

Quanto mais importante e crítico é o sistema, mais robusto deve ser o mecanismo de autenticação. Por exemplo, autenticação por dois fatores, visto mais à frente neste capítulo.

Autorização é o conjunto de ações que uma credencial pode executar no sistema, ou seja, quais atividades determinada pessoa, aplicação ou determinado recurso pode fazer no sistema.

Por exemplo, quando um aluno é autenticado pela catraca e entra na faculdade, ele vai ter acesso a quais ambientes (salas, laboratórios, espaços físicos em geral)? De quais cursos ou disciplinas ele está liberado para participar? Quer dizer, quais atividades ele pode fazer dentro da faculdade?

Da mesma forma, quando um usuário faz login em um sistema, ele poderá executar algumas atividades, por exemplo, um usuário de banco de dados que tenha autorização para criar objetos (tabelas, índices, procedures, funções) deverá receber os privilégios de Create Table, Create Procedure e Create Function.

A Figura “Autenticação e autorização”**Erro! Fonte de referência não encontrada.** resume essas definições.

Figura 1 – Autenticação e autorização
Fonte: DaNeil (2019)

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

Importante salientar que os privilégios devem ser concedidos conforme necessidade real, aplicando o princípio do menor privilégio, visto mais à frente neste capítulo.

1.3 Autenticação por dois fatores (Two Factor Authentication – TFA ou 2FA)

Com o crescente uso da internet para resolver as coisas mais rapidamente, a vida das pessoas quase que inteira está caminhando em direção ao digital. Desde coisas simples, como compras pela internet, até atividades mais complexas e financeiramente mais perigosas, como operar no mercado de valores com aparelhos smartphones ou similares (TWILIO AUTHY, 2022).

Levando isso em consideração, a proteção desses acessos digitais teve que ser revisada e melhorada. Assim, foi criada a autenticação por dois fatores e até mesmo a autenticação por múltiplos fatores (MFA – Multiple Factor Authentication).

O 2FA é uma camada extra de proteção para autenticação de um usuário. Geralmente o usuário fornecerá o nome para login e senha, mas, mesmo com isso, não será concedido imediatamente acesso ao sistema, sendo necessária uma segunda forma de validação, por exemplo, um número PIN enviado por SMS, um token gerado por algum outro mecanismo, um e-mail com o link para a segunda autenticação, entre outros recursos.

Até mesmo as contas de e-mail, quando configuradas corretamente, implementam a verificação em dois fatores, com login e senha como padrão e adicionada a isso uma string gerada aleatoriamente e enviada via SMS para o celular cadastrado.

Isso tenta garantir uma camada a mais de proteção para acesso ao sistema digital.

1.4 Princípio do privilégio mínimo

O princípio do privilégio mínimo é a ideia de que qualquer usuário, programa ou processo deve ter apenas os privilégios mínimos necessários para desempenhar sua função. Isso significa que apenas os direitos mínimos necessários devem ser atribuídos para o acesso a um recurso e devem estar em vigor pelo menor período

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

necessário. Conceder permissões a um usuário além do escopo dos direitos necessários de uma ação pode permitir que esse usuário obtenha ou altere informações de maneiras indesejadas, mesmo que sem intenção.

Por exemplo, uma conta de usuário criada para armazenar arquivos em um bucket S3 da AWS não precisa de direitos de administrador no mesmo bucket. O princípio do privilégio mínimo (POLP – Principle Of Least Privilege) também pode ser referido como o princípio do privilégio mínimo (POMP – Principle Of Minimal Privilege) ou o princípio da autoridade mínima (POLA – Principle Of Minimum Authority). Seguir o princípio do privilégio mínimo é considerado uma prática recomendada em segurança da informação (LORD, 2020).

Seguindo essa estratégia, é necessário criar individualmente um acesso diferente para cada usuário, sistema ou recurso e garantir que eles tenham somente os privilégios necessários (GEGICK; BARNUM, 2021). Assim, por exemplo, em vez de manipular sistemas Linux sempre com o usuário root, é mais indicado ter um usuário com privilégios administrativos para cada profissional. De forma semelhante, em vez de acessar o Banco de Dados Oracle com o usuário sys ou sysdba, é mais indicado criar contas específicas para cada perfil de acesso e profissional.

Benefícios do privilégio mínimo (ROSENCRANCE, 2021):

- Impede a propagação de malware. Ao adotar a estratégia POLP, é bem menos provável que algum mecanismo de malware se espalhe utilizando acessos administrativos.
- Diminui as chances de um ataque cibernético. A maioria dos ataques cibernéticos ocorre quando um invasor explora credenciais privilegiadas. O POLP protege os sistemas, limitando o dano potencial que pode ser causado por um usuário não autorizado que obtém acesso a um sistema.
- Melhora a produtividade do usuário. Apenas dar aos usuários o acesso necessário para concluir as tarefas necessárias significa maior produtividade e menos solução de problemas.
- Ajuda a demonstrar conformidade. No caso de uma auditoria, uma organização pode comprovar sua conformidade com os requisitos regulatórios apresentando os conceitos POLP que implementou.

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

- Ajuda na classificação de dados. Os conceitos POLP permitem que as empresas acompanhem quem tem acesso a quais dados em caso de acesso não autorizado.

A Figura “Benefícios do POLP” mostra a lista de benefícios explicada anteriormente.

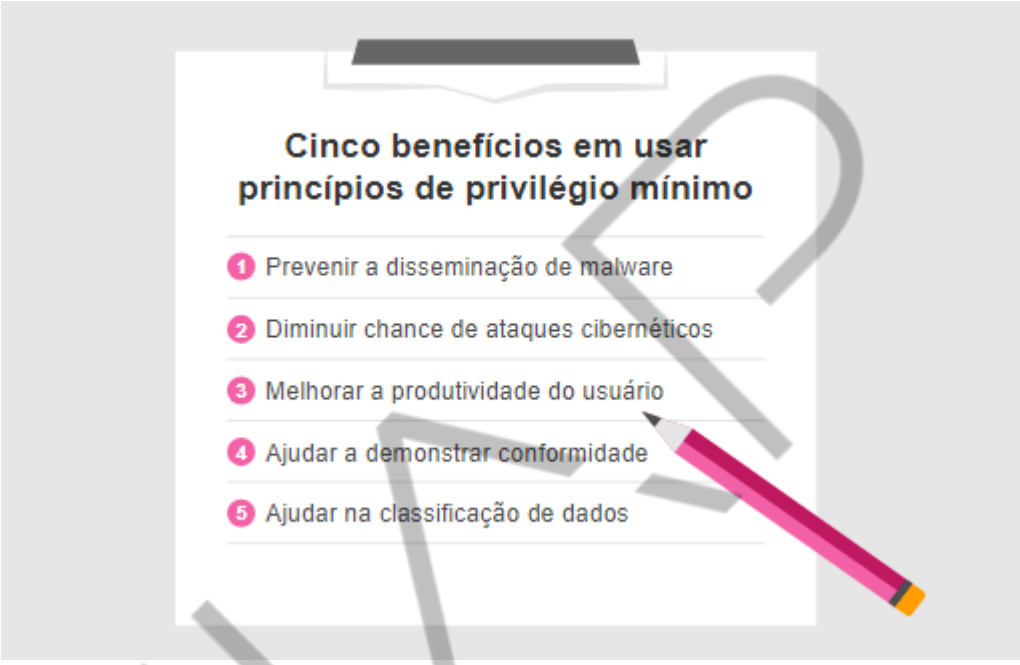


Figura 2 - Benefícios do POLP
Fonte: Rosencrance (2021)

1.5 Firewall e Web Application Firewall (WAF)

O firewall é um mecanismo de proteção de rede que atua na camada TCP/IP analisando os pacotes de dados que chegam e saem do ambiente computacional. Pode ser implementado por um programa específico ou um equipamento (hardware) no nível físico da rede.

Da mesma forma que no ambiente *on-premise,* é necessário configurar uma série de regras de entrada e saída de pacotes da rede de dados do ambiente em nuvem.

A atuação na camada lógica é realizada com análise dos pacotes de dados TCP que entram ou saem da rede. De forma geral, os mecanismos analisam os IPs origem e destino e também as portas de origem e destino. Por exemplo, em uma aplicação Web, o servidor HTTP deve ser acessado por qualquer usuário da internet

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

por meio do IP do servidor e geralmente a porta 80. Mas o servidor de banco de dados que esse sistema acessa não deve estar exposto à internet, sendo possível acessar somente pela aplicação. Dessa forma, nesse ambiente seria criada uma regra no firewall permitindo somente acesso à porta 80 do servidor Web.

Além da análise dos dados de destino e origem (IP e porta), os firewalls também podem analisar outros conteúdos dos pacotes, impedindo ataques do tipo DoS (Denial of Service) ou DDoS (Distributed Denial of Service) que podem sobrecarregar de requisições um servidor Web e acabar derrubando os serviços.

Para incrementar a proteção do firewall, muitos sites e aplicações Web têm implementado o Web Application Firewall (WAF), uma camada extra de proteção de aplicações que estão expostas diretamente na internet e que assim podem sofrer os mais diversos ataques vindos de vários lugares do mundo.

O WAF filtra os pacotes com o protocolo HTTP (ou HTTPS) analisando o conteúdo e registrando (log) os acessos para que seja possível rastrear de onde vem cada requisição e descobrir de onde podem vir os possíveis ataques.

Imagine como serviços cotidianos se protegem, por exemplo, o Waze, os sites de e-commerce, os sites de conteúdo, os aplicativos de instituições financeiras etc.

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

2 HANDS-ON – CRIANDO E CONFIGURANDO UMA CONTA NA NUVEM ORACLE

O objetivo deste hands-on é criar uma conta da nuvem Oracle e limitar seu uso para que possa somente criar e gerenciar instâncias de máquinas virtuais, nada mais além disso.

Para implementar essa função, será necessário:

- Uma conta na nuvem Oracle (OCI – Oracle Cloud Infrastructure).

Seguir a sequência de ações

Fazer o login na conta do Oracle Cloud Infrastructure e, no menu principal do Oracle Cloud, escolher a opção “Identity & Security” → “Users”, conforme Figura “Identidades e segurança”:

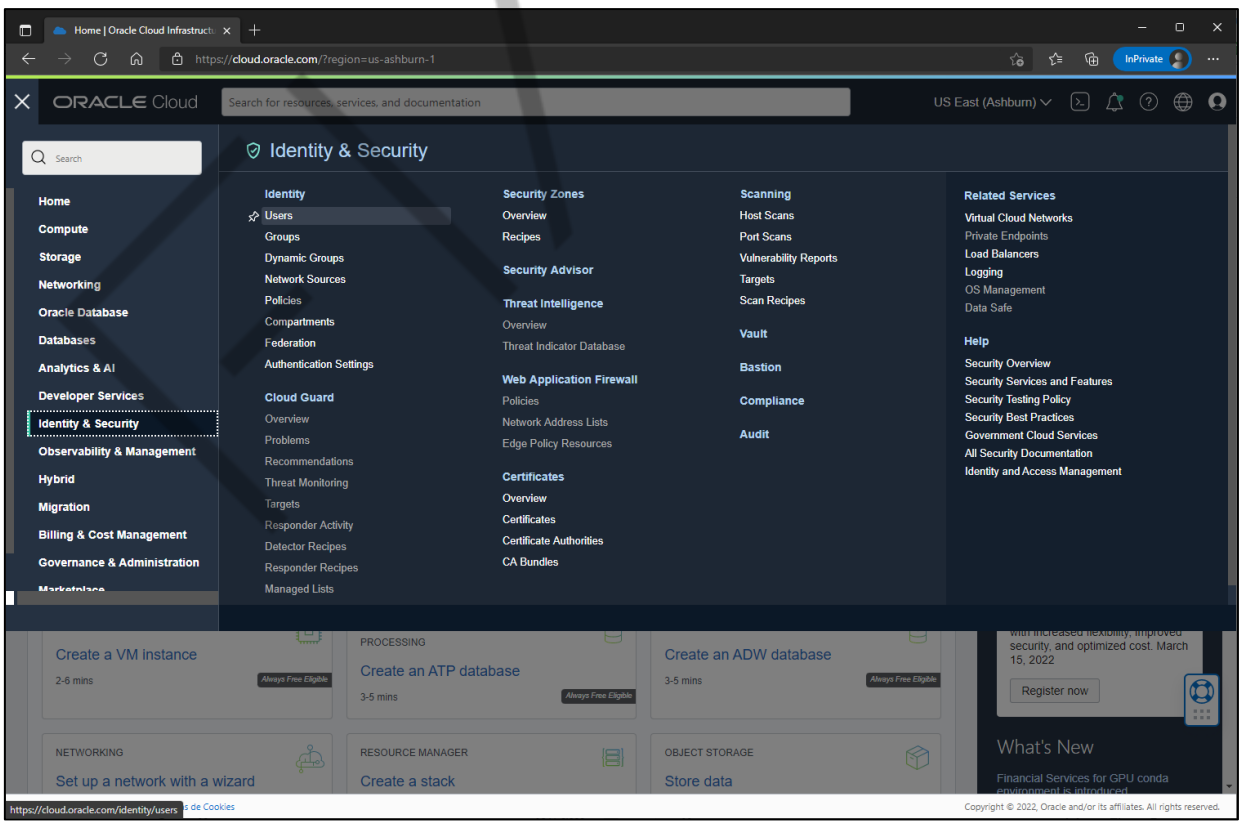


Figura 3 – Identidades e segurança
Fonte: Elaborado pelo autor (2022)

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

Na seção “Identity”, serão utilizados os itens “Users”, “Groups” e “Policies”, nessa sequência.

Clicar em “Users” e no botão “Create User”, conforme Figura “Criar novo usuário”:

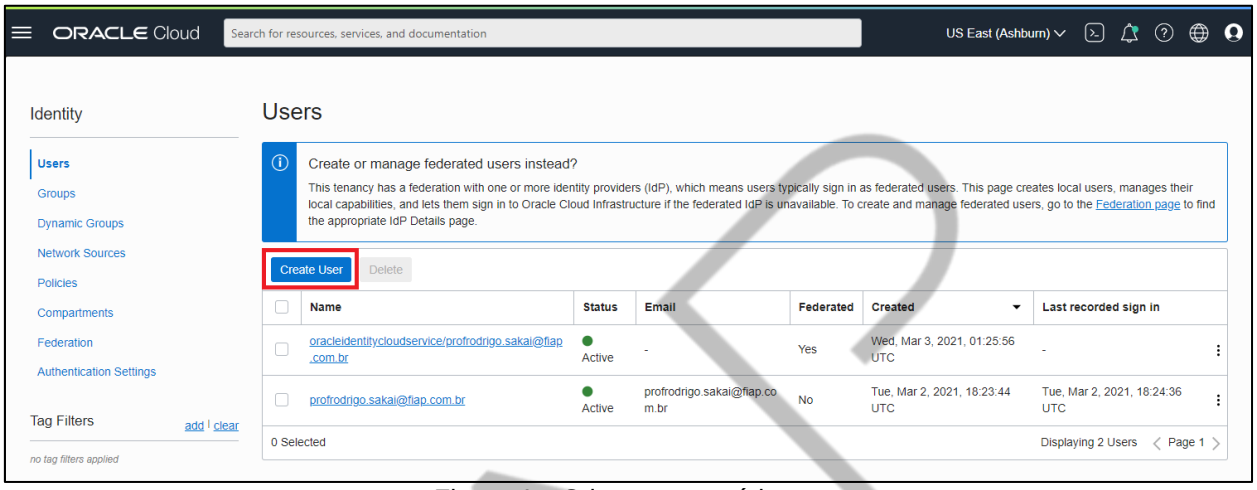


Figura 4 – Criar novo usuário
Fonte: Elaborado pelo autor (2022)

Escolher a opção “IAM Users” e preencher o nome do usuário e a respectiva descrição. A Figura “Configurar novo usuário” exemplifica essas opções:

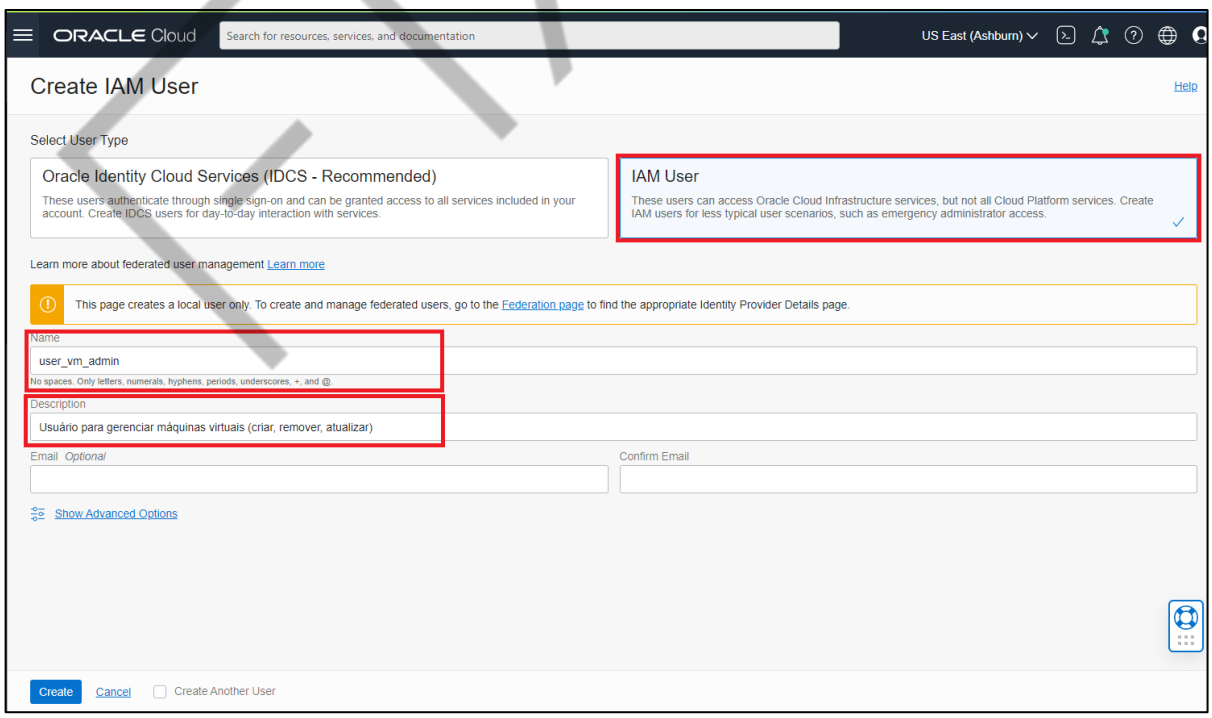


Figura 5 – Configurar novo usuário
Fonte: Elaborado pelo autor (2022)

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

Após a criação do novo usuário, aparecerá a seção contendo as informações relativas a esses usuários e algumas ações possíveis, entre elas “Create/Reset Password”, que será utilizada para configurar a senha inicial desse usuário, conforme Figura “Configurar nova senha para o usuário”.

Também é possível identificar um botão para habilitar a autenticação de dois fatores, conforme visto neste capítulo, porém essa opção não será utilizada neste hands-on.

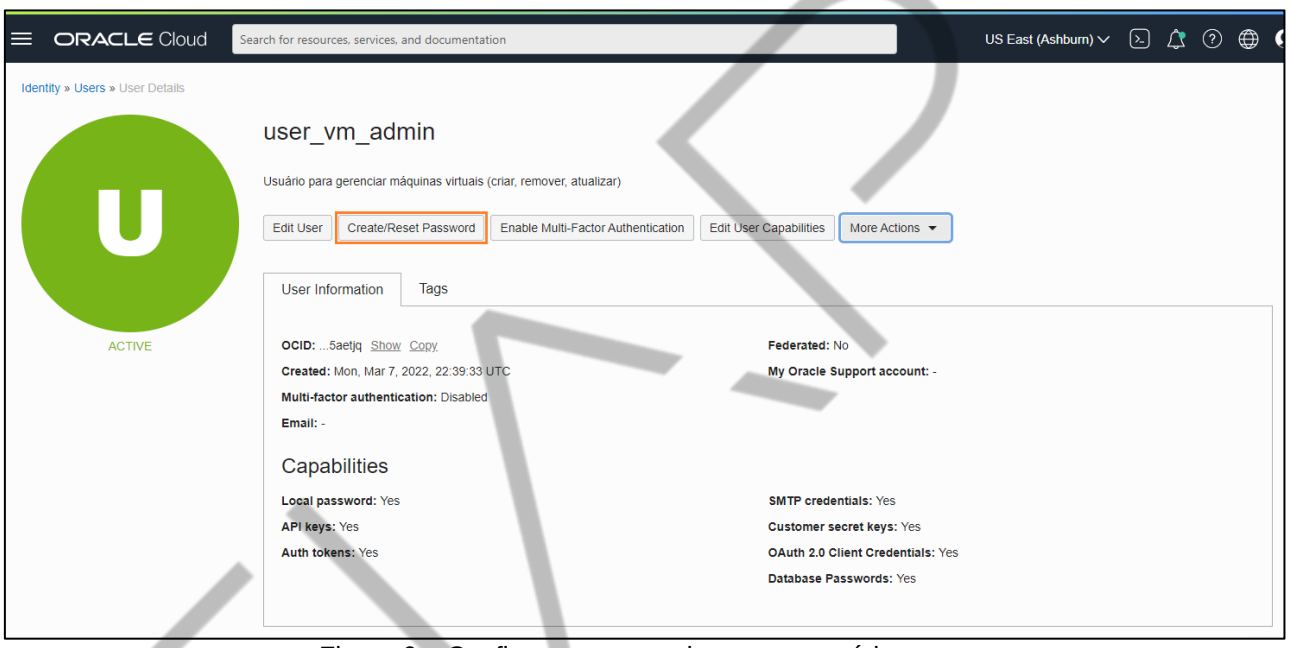


Figura 6 – Configurar nova senha para o usuário
Fonte: Elaborado pelo autor (2022)

Clicar em “Create/Reset Password” para criar a senha inicial do usuário.

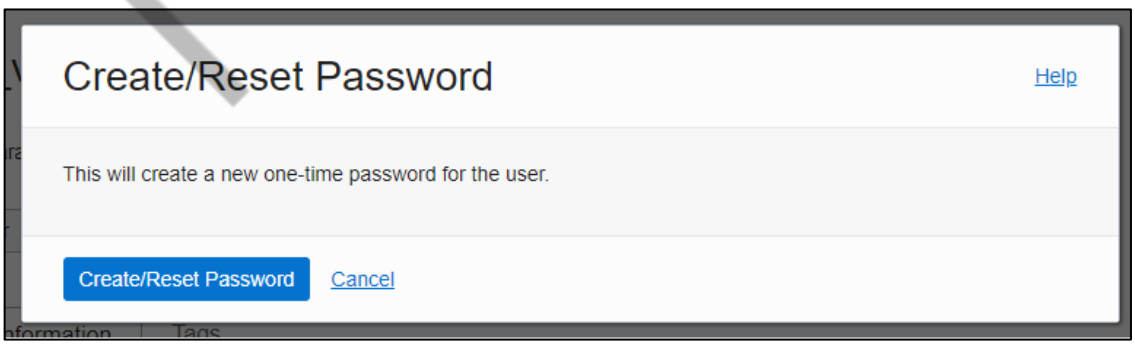


Figura 7 – Criar nova senha
Fonte: Elaborado pelo autor (2022)

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

Clicar no link para mostrar a senha e copiá-la em algum lugar, pois será utilizada em uma etapa posterior. A Figura 8“Nova senha criada” exemplifica essa ação.

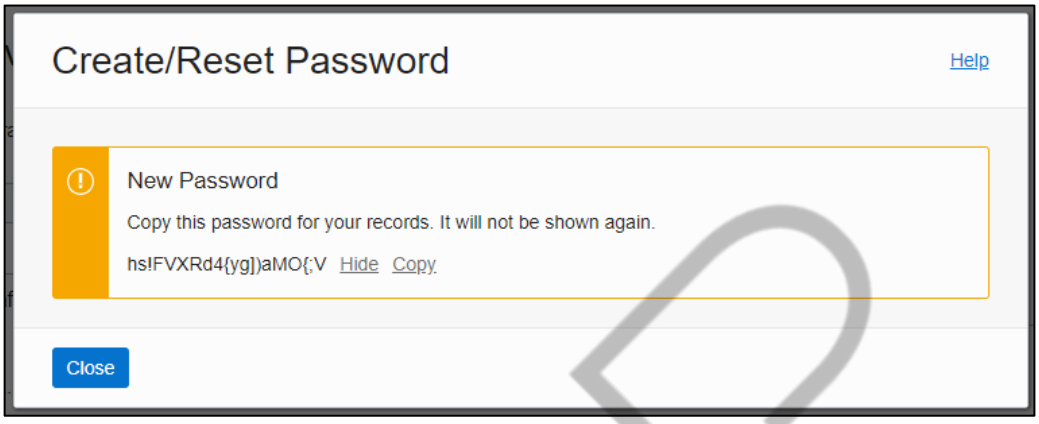


Figura 8 – Nova senha criada
Fonte: Elaborado pelo autor (2022)

A etapa a seguir é a criação de um novo grupo de usuários. Todo usuário deve pertencer a pelo menos um grupo, pois as políticas de acesso são aplicadas aos grupos e não aos usuários.

Clicar em “Create Group”, conforme Figura “Criar novo grupo de usuários”.

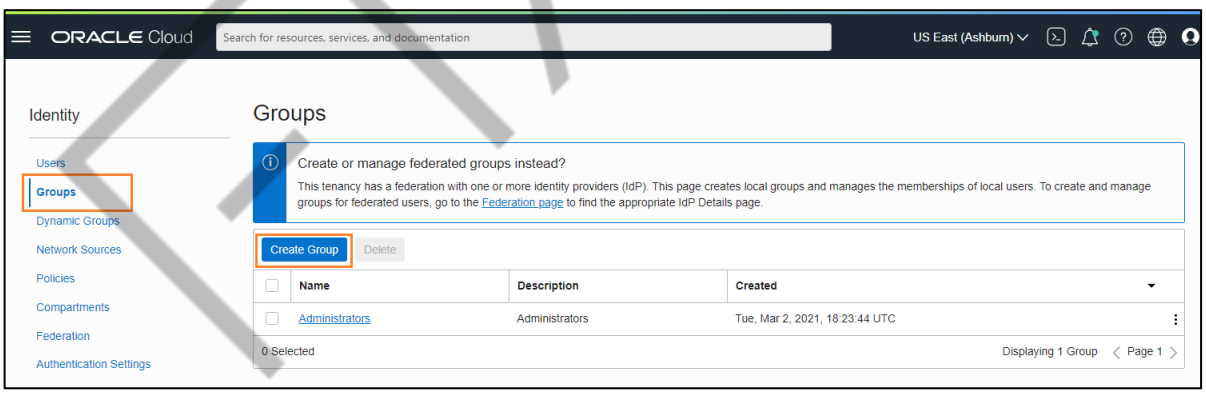


Figura 9 – Criar novo grupo de usuários
Fonte: Elaborado pelo autor (2022)

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

Configurar as informações solicitadas para o novo grupo, como o nome e a descrição. A Figura “Configurar novo grupo de usuários” mostra essas opções.

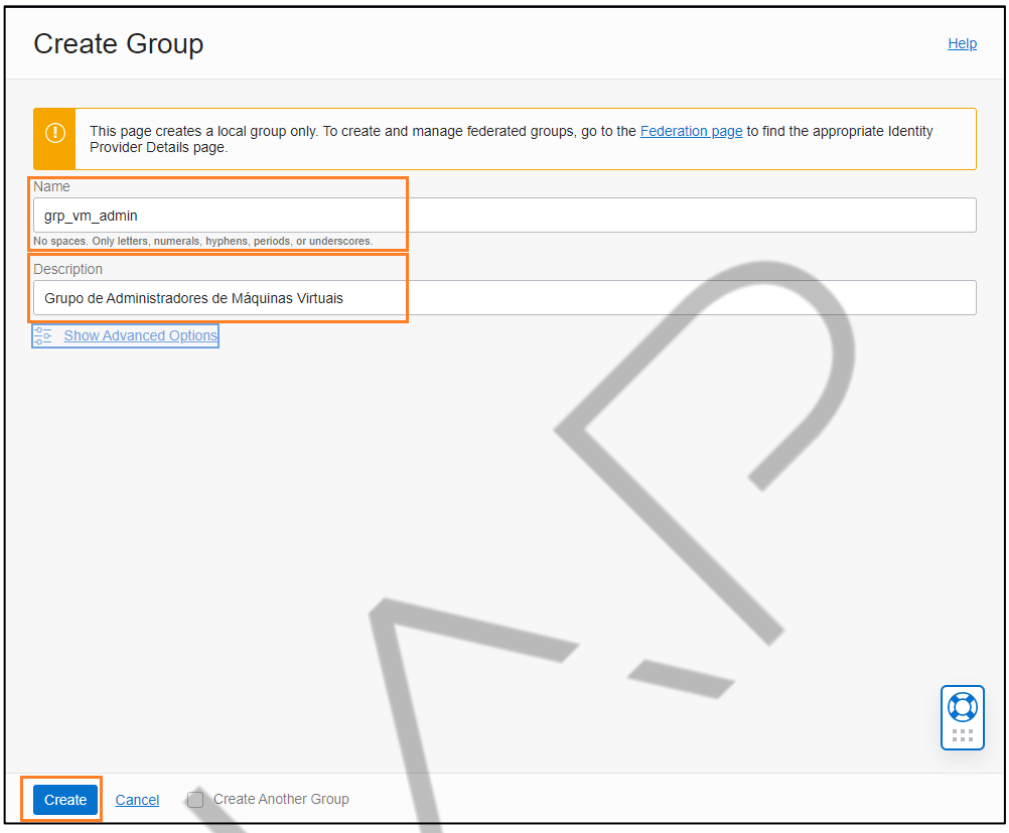


Figura 10 – Configurar novo grupo de usuários
Fonte: Elaborado pelo autor (2022)

Após a criação do grupo, uma seção com as informações dele será apresentada. Nessa seção, é possível adicionar membros (usuários), bastando clicar em “Add user to Group”, conforme Figura “Adicionar membros (usuários) ao grupo”.

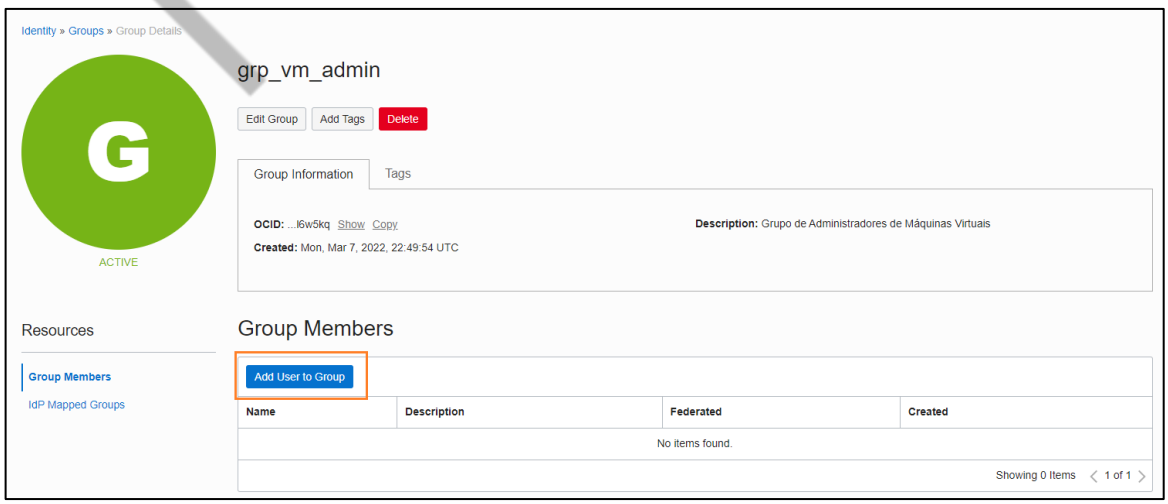


Figura 11 – Adicionar membros (usuários) ao grupo
Fonte: Elaborado pelo autor (2022)

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

O menu da Figura “Adicionar membros (usuários) ao grupo” será mostrado, clicar na lista suspensa e selecionar o usuário criado na etapa anterior. Clicar em “Add”, assim o usuário está incluso no novo grupo criado. Esse passo pode ser repetido sempre que for necessário incluir outro usuário ao grupo.

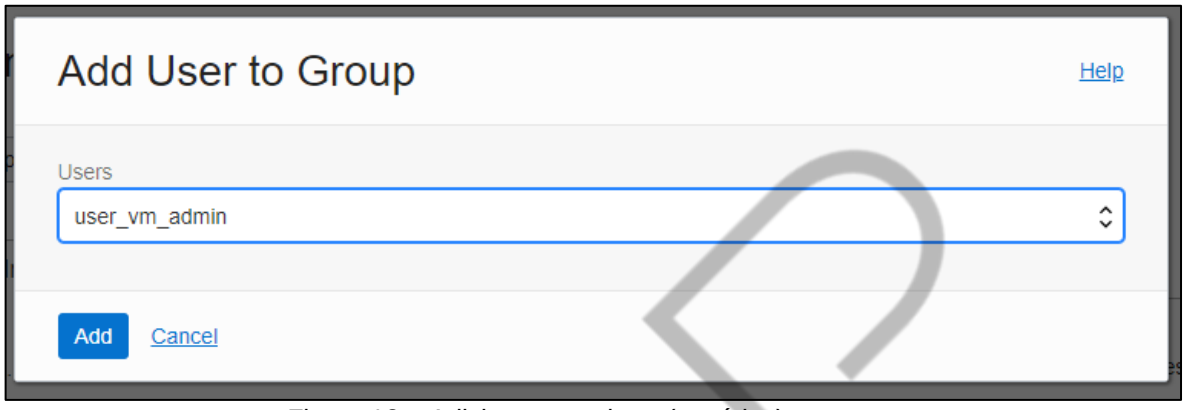


Figura 12 – Adicionar membros (usuários) ao grupo
Fonte: Elaborado pelo autor (2022)

Nessa etapa será criada a política de regras que será aplicada ao grupo criado. Essa política permitirá aos usuários do grupo administrarem as máquinas virtuais, ou seja, criação, remoção e alteração das máquinas virtuais.

Conforme Figura “Criar política de regras”, clicar no link “Policies” e posteriormente no botão “Create Policy”.

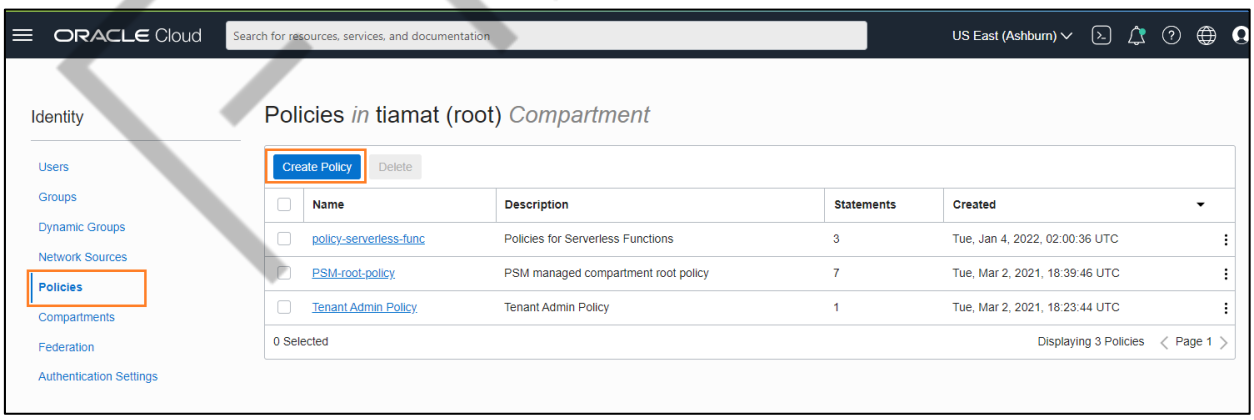


Figura 13 – Criar política de regras
Fonte: Elaborado pelo autor (2022)

Preencher a nova política com as informações: nome, descrição, compartimento e as regras (statements). A Figura 14“Configurar política de regras” exemplifica esse preenchimento. Clicar em “Create” para finalizar a criação da política.

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

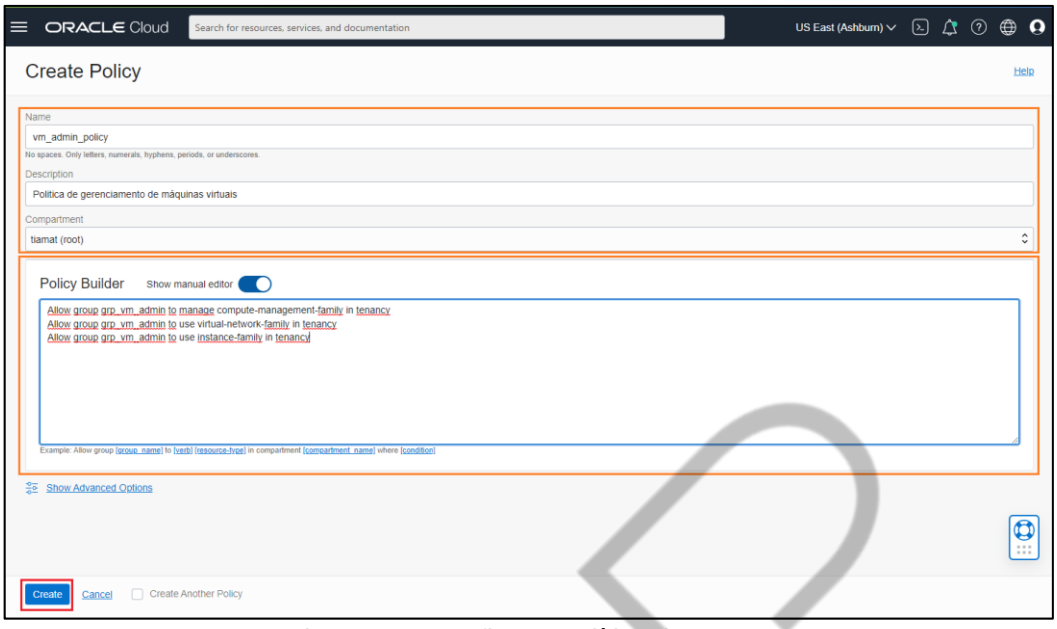


Figura 14 – Configurar política de regras
Fonte: Elaborado pelo autor (2022)

A **Erro! Fonte de referência não encontrada.**Tabela “Valores da política criada” apresenta os valores exatos a serem preenchidos. Note que as regras são aplicadas ao grupo criado anteriormente.

Somente são concedidas as regras necessárias à ação de gerenciamento de máquinas virtuais.

Campo	Valor
Nome	vm_admins_policy
Descrição	Política de gerenciamento de máquina virtuais
Compartment	Tiamat (root)
Policy Builder	Allow group grp_vm_admin to manage instance-family in tenancyAllow group grp_vm_admin to use virtual-network-family in tenancyAllow group grp_vm_admin to use volume-family in tenancy

Tabela 1 – Valores da política criada
Fonte: Elaborado pelo próprio autor (2022)

Após a criação da política de regras, fazer logoff do usuário principal que estava sendo utilizado e fazer o login utilizando o novo usuário e a senha inicial configurada. A Figura “Login com o novo usuário criado” exemplifica essa ação. Perceba que, em

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

vez de clicar em “Continue”, é necessário usar a parte de baixo preenchendo com o nome do usuário e a respectiva senha.

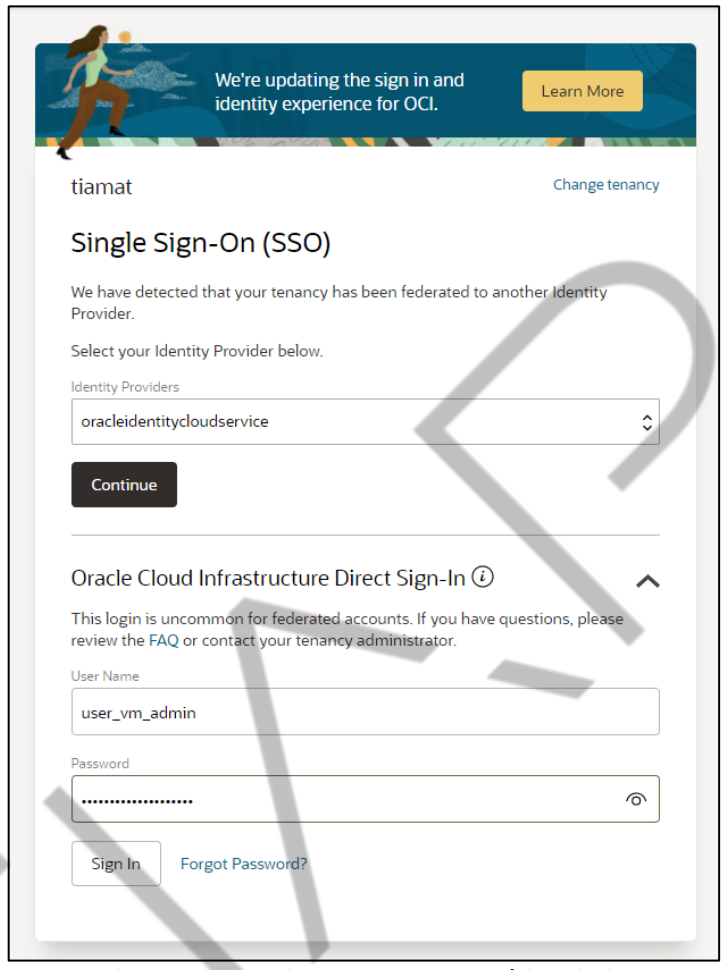


Figura 15 – Login com o novo usuário criado
Fonte: Elaborado pelo autor (2022)

Configurar uma nova senha respeitando as regras de formação de senha forte. A figura “Alterar a senha do novo usuário” mostra essa etapa.

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

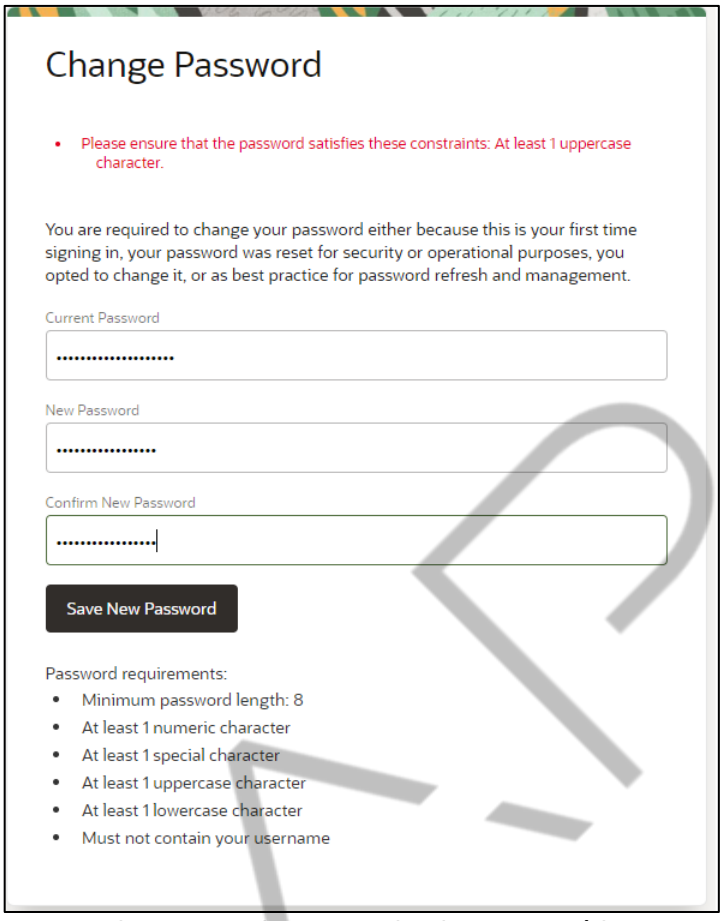


Figura 16 – Alterar a senha do novo usuário
Fonte: Elaborado pelo autor (2022)

Após o login com o novo usuário, tente criar uma nova máquina virtual (instância) para certificar-se de que as regras criadas são suficientes para executar essa ação.

Tente também efetuar algumas outras ações diferentes da proposta, por exemplo, criar um novo backup para também certificar-se da impossibilidade de executar essa ação conforme as regras configuradas.

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

CONCLUSÃO

Os mecanismos de proteção de ambientes digitais são muitos e muito bem desenvolvidos, porém nada substitui o conhecimento e a consciência dos usuários sobre os procedimentos de segurança pessoal e corporativo.

A segurança do ambiente em nuvem deve ser implementada pelos provedores e atendida pelos usuários, isso significa que é uma estratégia para ser planejada, implementada e seguida pelas duas partes do ambiente, fornecedores e clientes.

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

ATIVIDADE TREINO

Essa atividade não é avaliativa, caso queira ter um feedback, entre em contato com seu tutor pelo Teams

Uma das regras básicas de segurança de ambientes digitais é criar usuários individuais para a execução de tarefas de gerenciamento e monitoração. Usando a nuvem da Oracle desenvolva os exercícios a seguir.

1. Crie um usuário e um grupo para o gerenciamento de redes virtuais (VPCs).

2. Crie uma política para possibilitar que esse grupo possa criar novas VPCs e subnets. Aplique a política ao grupo criado anteriormente.

3. Faça login com o usuário criado anteriormente e crie uma nova VPC com uma sub-rede pública e outra sub-rede privada.

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com

REFERÊNCIAS

DANEIL C. **AUTHeNtication VS AUTHoriZation**. 2019. Disponível em: https://dev.to/caffiendkitten/authentication-vs-authorization-25lc. Acesso em: 1 mar. 2022.

GEGICK, M.; BARNUM, S. Least Privilege. 2013. *In:* EUA. **Cibersecurity & Infrastructure Security Agency.** Disponível em: https://www.cisa.gov/uscert/bsi/articles/knowledge/principles/least-privilege. Acesso em: 1 mar. 2022.

LORD, N. What is the Principle of Least Privilege (POLP)? 2020. A Best Practice for Information Security and Compliance. **Digital Guardian.** Disponível em: https://digitalguardian.com/blog/what-principle-least-privilege-polp-best-practice-information-security-and-compliance. Acesso em: 1 mar. 2022.

ROSENCRANCE, L. Principle of least privilege (POLP). 2021. **Techtarget.** Disponível em: https://www.techtarget.com/searchsecurity/definition/principle-of-least-privilege-POLP. Acesso em: 01 mar. 2022.

TWILIO AUTHY. **What Is Two-Factor Authentication (2FA)?** 2022. Disponível em: https://authy.com/what-is-2fa/. Acesso em: 01 mar. 2022.

FIAP

PDF exclusivo para Marcos Antonio Vieira de Almeida - rm559875
marcosdaguealmeida@outlook.com